Injection Attacks: When User Input Becomes a Weapon

GROUP MEMBER :

Muhammad Luqman Nul Hakeem Bin Mohd Shukri CI260175
Wan Muhammad Azeem Bin Mohd Rizaudin CI260176
Muhammad Syaaban Bux Bin Rahman Bux DI250040
Mohamad Norfarhan Bin Mohammad Puhat CI260088

Lecturer : Mr Khairul Amin

1.Introduction to OWASP

1.1What is OWASP, and why is it important?

OWASP stands for the Open Worldwide Application Security Project. Its a open community that helps organizations develop,buy and maintain application and APIs that can be trusted by user. OWASP is a non profit entity behind it and almost everyone who involved with OWASP is a volunteer. OWASP always gives away free tools,guides and research. Its independent and isn’t owned by any tech company, that’s why its advice trustworthy.

1.2 What is the OWASP Top 10, and how does it help organizations?

OWASP Top 10 can be regarded as an awareness document for web application security. This list encompasses a general agreement on the top security threats for web applications.

1.3 How often is the OWASP Top 10 updated, and why does it change?

I noticed that the list gets updated roughly every three to four years. For example 2017,2021,2025. The last edition was released in 2021. Then the 2025 edition came out on November 6 2025. The final edition was released in January 2026.

2.1 Risk Description

Injection occurs when a web applicatopn sends information from a user to a database, a browser or an operating system without checking it.The system them thinks the information is a command and runs it. Some common types are SQL injection, OS command injection and cross-site scripting (XSS). In the OWASP Top 10:2025 Injection is in the position (A05) which is lower, than third but it still has the most reported CVEs compared to any other category.

2.2 How it happens

An application is open to injection when it fails to check, clean or filter the data that users send. It becomes vulnerable when it creates database queries by adding user input to text rather than using safer techniques like parameterized queries. Attackers search for every way to enter data like login forms, search boxes, URL parameters, cookies or headers. Any weak spot is a chance, for an attack.

OWASP gives a simple example. Imagine a website that looks up a customer account using this code:

SELECT * FROM accounts WHERE custID='" + id + " ' "

If a normal user sends an ID like 123, the website returns only that customer’s account. But an attacker can change the id in the URL to ' OR '1'='1. The query then becomes:

SELECT * FROM accounts WHERE custID='' OR '1'='1'

Because '1'='1' is always true the database returns every record, in the accounts table. In a case the attacker could change or delete data. The root cause is that the application trusted the user’s input and let it change the meaning of the query.

3.0 Real-world case study: XSS attack on eBay (2014)

The main goal of this attack wasn't to crash servers, but to steal user login details using clever phishing tricks.

3.1 How it happened?

Back in September 2014, some attackers posed as normal sellers and hid malicious JavaScript inside product listings on eBay (like popular iPhone listings). When unsuspecting buyers clicked on the items, the script ran in their browsers and secretly redirected them straight to a fake eBay login page. Lots of people fell for it, typed in their real usernames and passwords, and handed their credentials right over to the hackers.

3.2 Impact of the attack

Since the attack targeted everyday users directly, it really shook people's confidence in buying or selling items on the platform. It proved how dangerous it is to let unfiltered, unsafe scripts sit inside user-generated product listings. eBay did clarify later that their main corporate network wasn't actually hacked it was just an abuse of the product listing feature but they still had to quickly yank down all the affected listings.

3.3 Ways To Prevent TheAttack

1. What happened in the breach?

Attackers hid harmful JS code inside eBay product listings. When buyers opened the items, the code forced their browsers to jump to a fake login page designed to steal passwords.

2. How does the breach relate to the selected OWASP risk?

This is a textbook case of Cross-Site Scripting (XSS), which falls under the Injection umbrella. eBay failed to filter out bad code from seller descriptions, meaning the site treated dangerous script tags like regular text and let them run on victims' browsers.

3. What could have prevented the attack?-

HTMLSanitization: Stripping out risky tags like <script> from anything sellers type into descriptions.-Output Encoding: Converting special characters (like < and >) into safe text entities so browsers don't accidentally execute them as code.-Content Security Policy (CSP): Setting up strict CSP headers to block random inline scripts and stop unauthorized redirects to external phishing sites.

4.0 Real-world case study: XSS attack on eBay (2014)

Main objective of the attack were to steal user's login information through phishing technique

4.1 How it happened?

On September 2014, An attacker act as a seller and placed JavaScript code in product listing on eBay's marketplace. Some listing such as listing for iPhones which successfully lure the victims to click the listing cause the victim's browser to redirect to fake eBay websites login page.

A lot of user has fallen into these trap and becomes a victim after they genuinely enter their usernames and passwords, which automatically allowing malicious attacker to steal their login credentials.

4.2 Impact of the attack

Since the target is the user itself, this cause the user to lose the confidence in purchase or listing an item on marketplace. This incident demonstrated the danger of allowing unsafe scripts in user-generated product listings. Ebay also stated eBay stated that the incident involved abuse of product listings, rather than a compromise of its entire corporate network. The affected listings were removed.

4.3 Reference

1. Infosecurity Magazine — eBay Under Fire After Cross Site Scripting Attack

2. https://owasp.org/

3. https://owasp.org/about

4. https://community.owasp.org/Injection_Flaws

5. https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html

6. https://www.bitdefender.com/en-us/blog/hotforsecurity/ebay-falls-victim-to-cross-sitescripting-attack